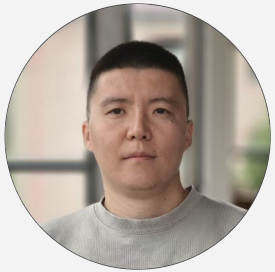
27 October 2026

Securing Kubernetes Cluster with Kubescape



Speaker



Maxat Akbanov

DevOps Engineer at Magnum Cash & Carry Kazakhstan

For more information see 👉 maxat-akbanov.com/about/

DataArt

epam Kazakhstan

magnum cash & carry

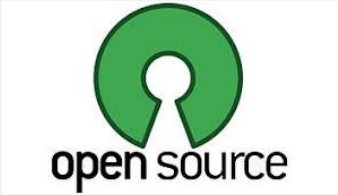
KAZAKHTELECOM

ioka

Yellow

What we needed?

- Alternative for Trivy scanner
  (Trivy Security incident 2026-03-19 #10425)
- Uses Grype engine under the hood
- Open source tool
- Able to scan container images, static manifest files and Kubernetes environment
- Easy integration with CI/CD pipelines
- Easy integration with ArgoCD









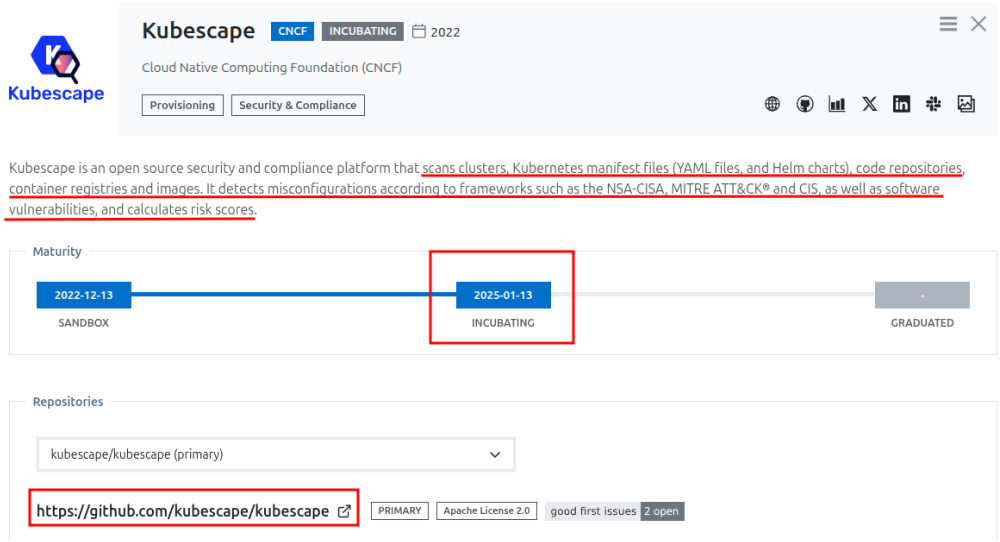
What is Kubescape?

ARMO
Creators of Kubescape

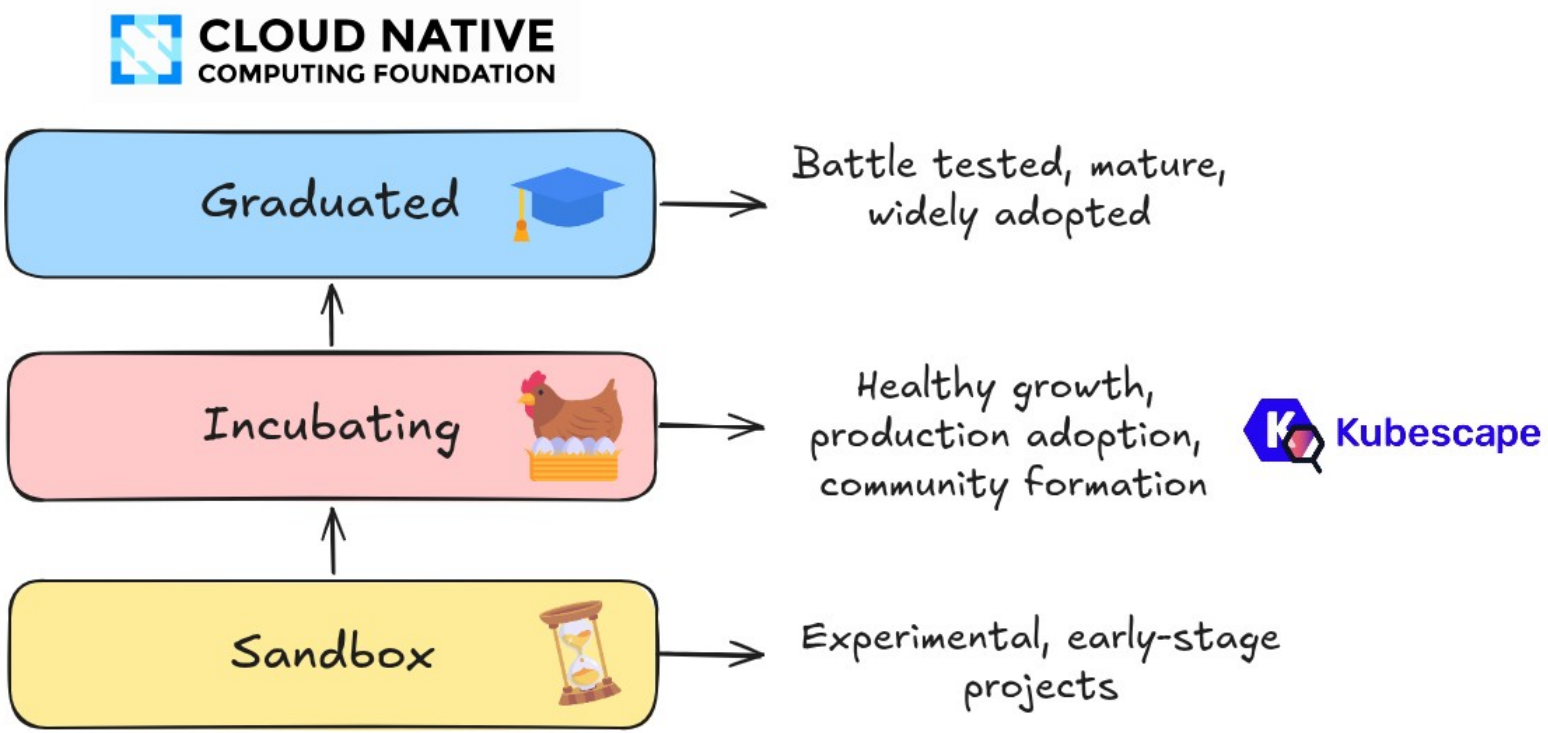
ARMO is an Israeli cybersecurity company focused on Kubernetes security

Donated Kubescape to CNCF to ensure vendor-neutral, community-driven development

ARMO remains the primary contributor and offers a commercial SaaS platform on top of the open-source core

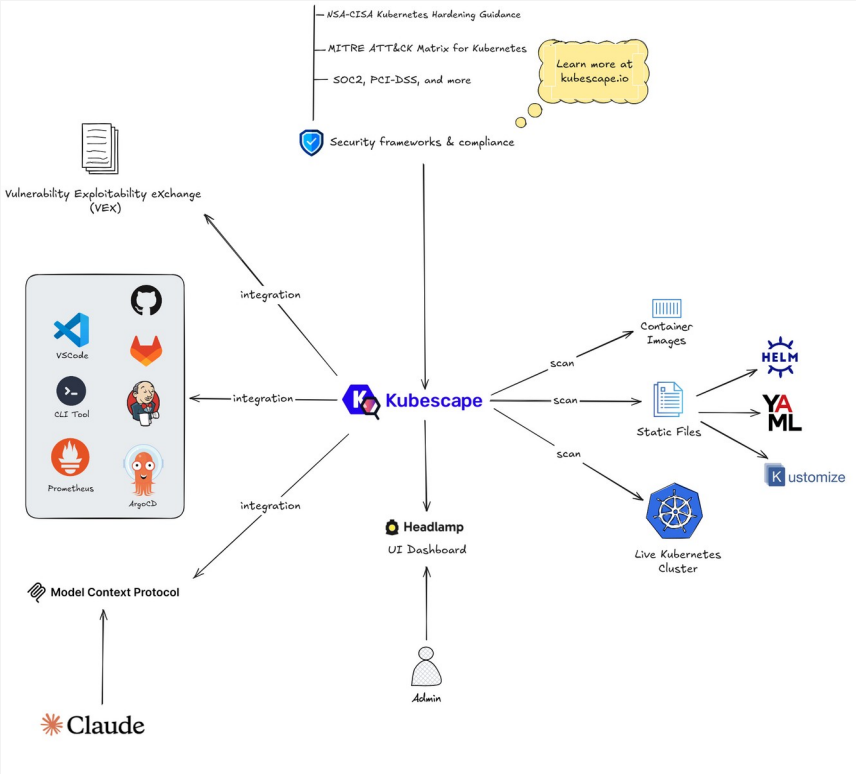


CNCF Maturity Levels

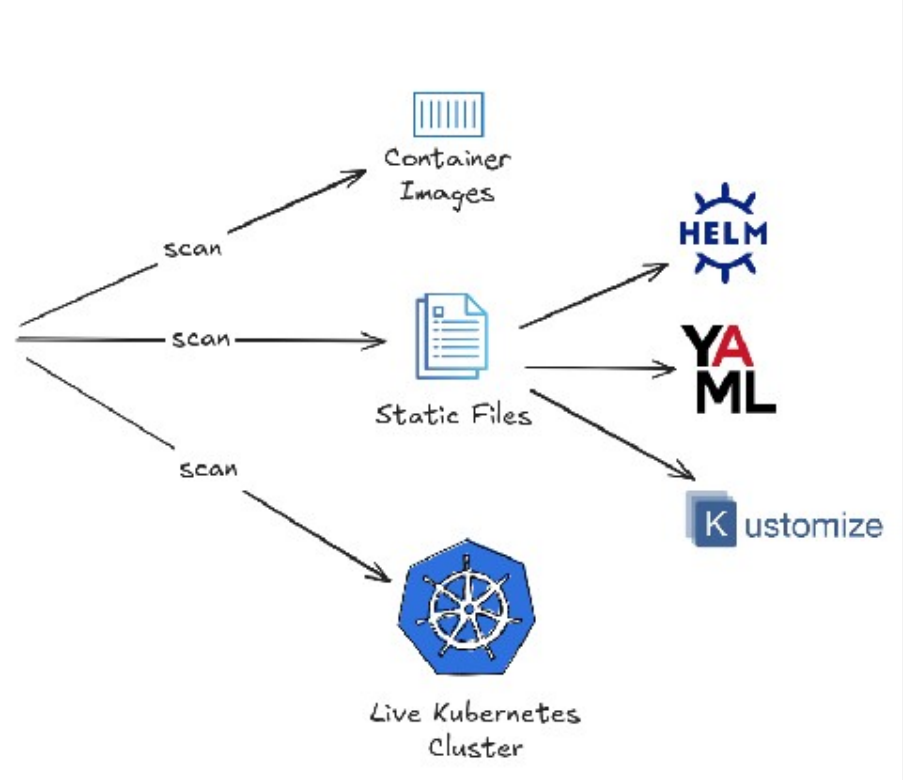


Kubescape Features

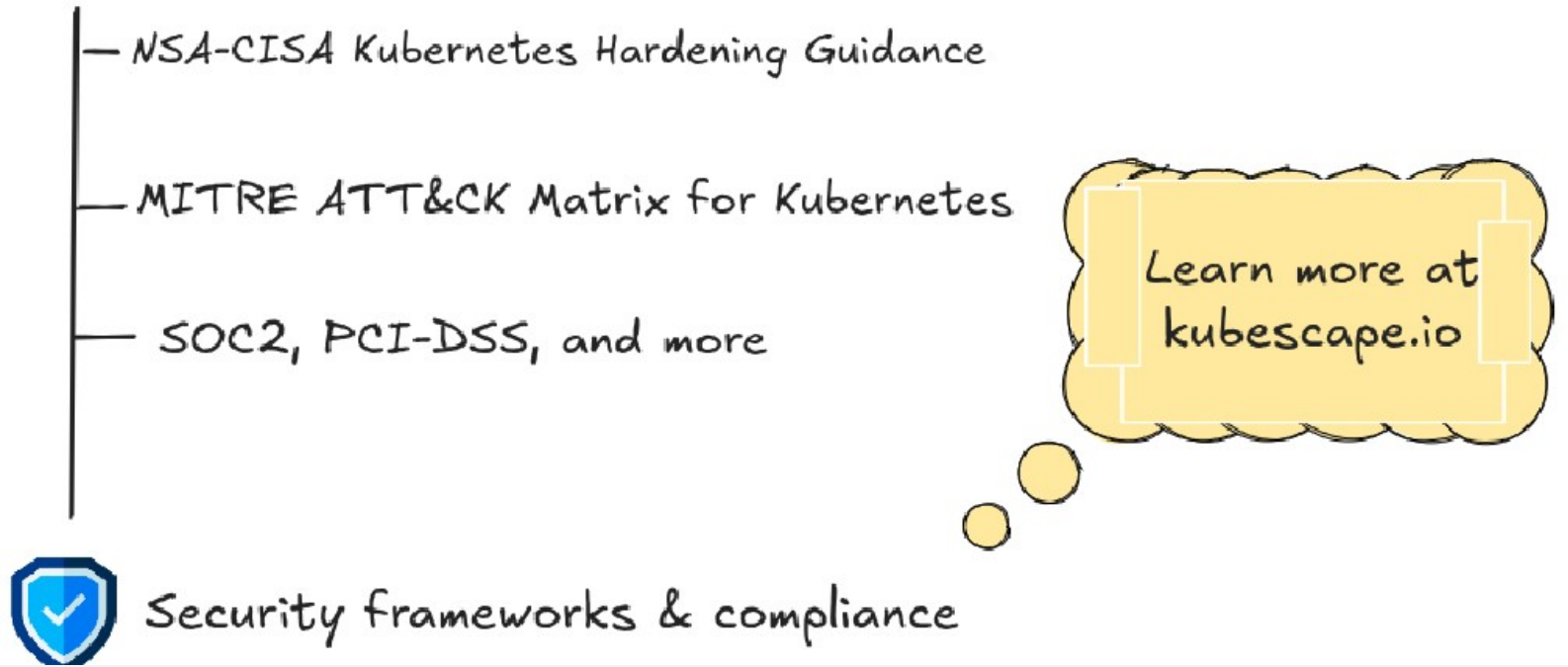
- Scans container images, static files and live K8s clusters
- Scans against the most popular security frameworks and custom rules
- Integrates with ArgoCD, GitLab, Prometheus, etc.
- Can provision its own MCP server for AI tools
- Can provision its own UI dashboard with Headlamp
- Generates VEX documents for security teams
- Learn more at kubescape.io



Scans: Container Images, Static Files and Live K8s Cluster



Security Frameworks and Custom Rules



Scan Cluster with Kubescape CLI

Kubescape Basic Commands

```
# Scan cluster against default frameworks (MITRE + NSA)
kubescape scan

# List available frameworks
kubescape list frameworks
kubescape list controls

# Scan against a specific framework
kubescape scan framework nsa
kubescape scan framework mitre

# Download a specific framework
kubescape download framework nsa

# Scan a specific control with details
kubescape scan control C-0260 -v

# Scan local manifest files
kubescape scan nginx-app.yml

# Scan a specific namespace only
kubescape scan --include-namespaces app

# Scan image
kubescape scan image nginx:latest-
```

v4.0.9

Supported frameworks
AllControls
ArmoBest
DevOpsBest
MITRE
NSA
SOC2
cis-aks-t1.2.0
cis-aks-t1.8.0
cis-eks-t1.7.0
cis-eks-t1.8.0
cis-gke-v1.9.0
cis-v1.10.0
cis-v1.12.0



Scan Cluster with Kubescape CLI

Secrets

Control name	Resources	View details
Applications credentials in configuration files	1	$ kubescape scan control C-0012 -v
Automatic mapping of service account	3	$ kubescape scan control C-0034 -v

Network

Control name	Resources	View details
Cluster internal networking	2	$ kubescape scan control C-0054 -v
Container hostPort	1	$ kubescape scan control C-0044 -v
HostNetwork access	1	$ kubescape scan control C-0041 -v
Ingress and Egress blocked	3	$ kubescape scan control C-0030 -v
Missing network policy	4	$ kubescape scan control C-0260 -v

Workload

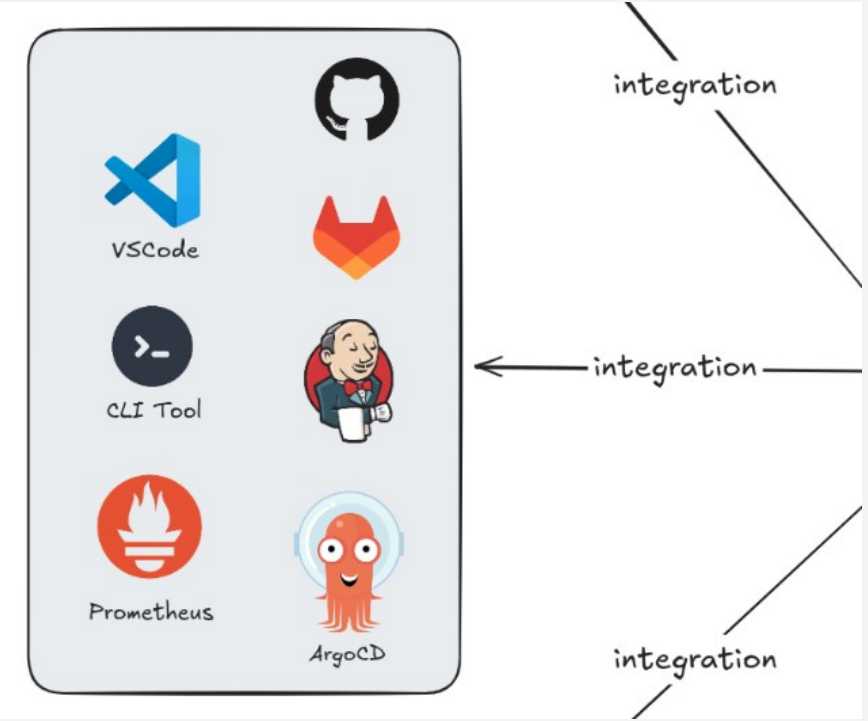
Control name	Resources	View details
CVE-2021-25741 - Using symlink for arbitrary host file system access.	0	$ kubescape scan control C-0058 -v
CVE-2021-25742-nginx-ingress-snippet-annotation-vulnerability	0	$ kubescape scan control C-0059 -v
Exposed sensitive interfaces	0	$ kubescape scan control C-0021 -v
Kubernetes CronJob	0	$ kubescape scan control C-0026 -v
Mount service principal	0	$ kubescape scan control C-0020 -v
SSH server running inside container	0	$ kubescape scan control C-0042 -v

Supply chain

Control name	Resources	View details
Anonymous access enabled	1	$ kubescape scan control C-0262 -v
Authenticated user has sensitive permissions	0	$ kubescape scan control C-0265 -v

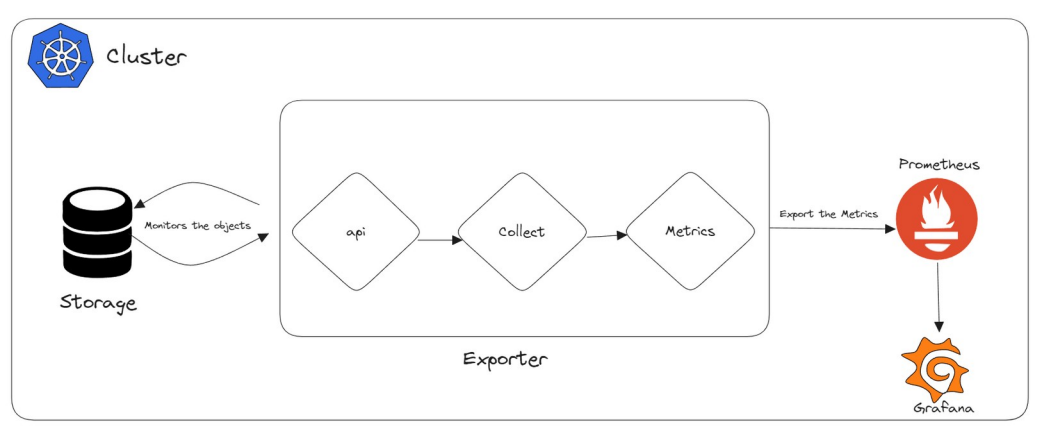
Integrations

Integrates with ArgoCD, GitLab, Prometheus, and more



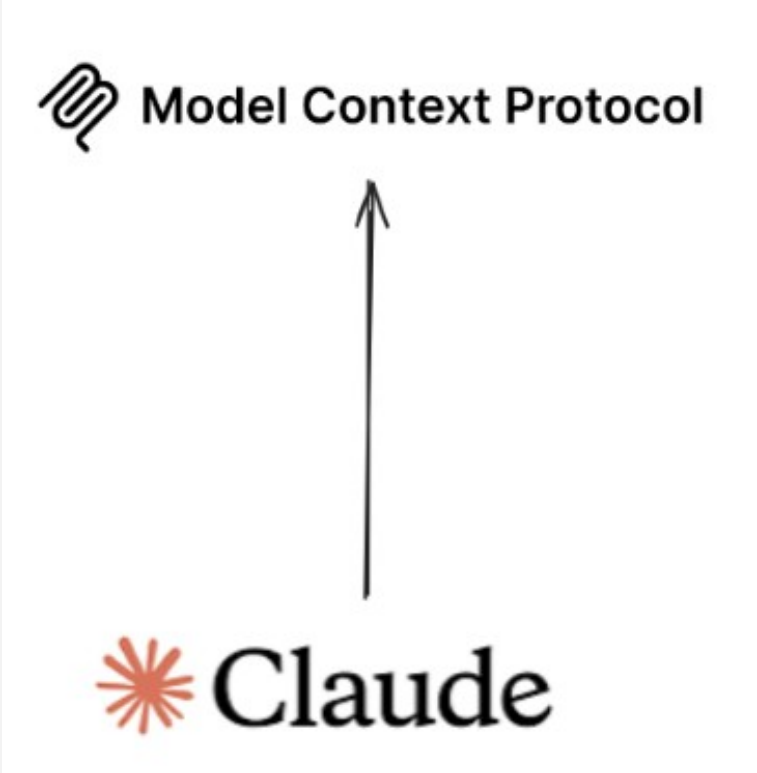
Kubescape Prometheus Metrics

- `kubescape_vulnerabilities_total_cluster_critical` - Total critical CVEs in the cluster
- `kubescape_vulnerabilities_total_namespace_high` - Total high CVEs by namespace
- `kubescape_vulnerabilities_total_workload_critical` - Total critical CVEs by workload
- Node-agent metrics such as `node_agent_alert_counter` when runtime detection is enabled

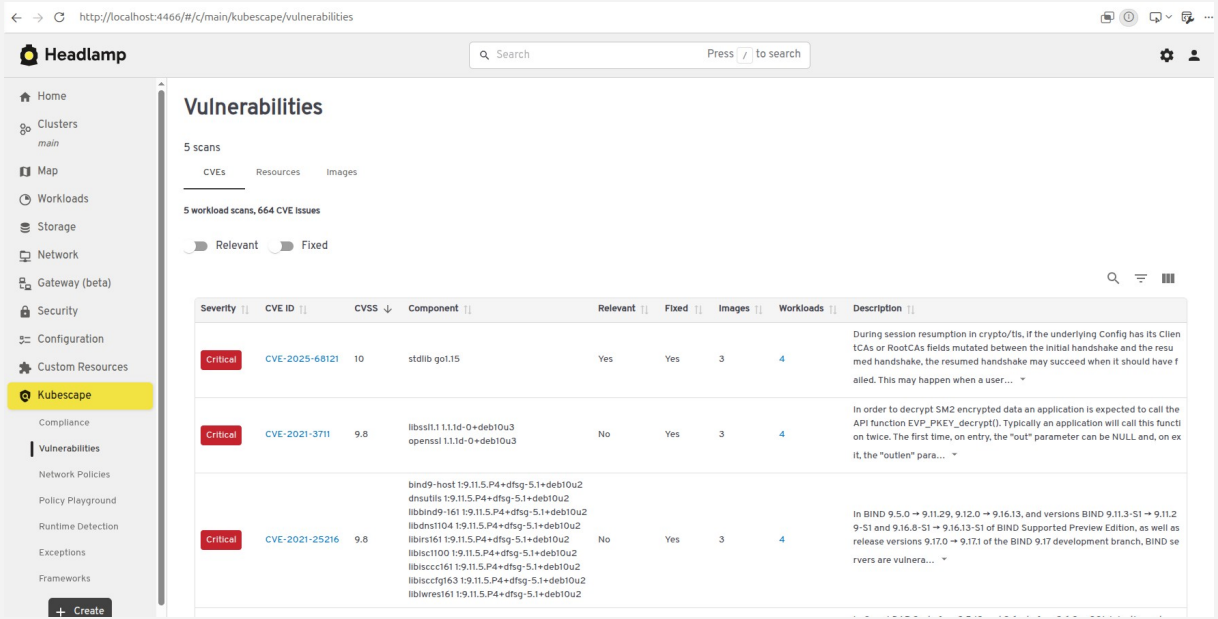


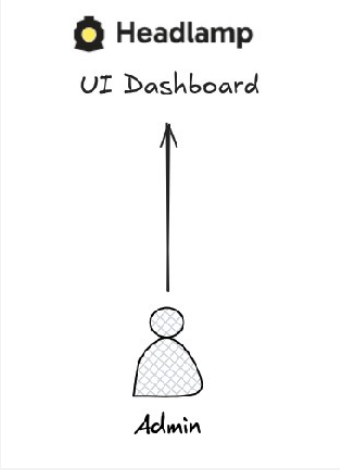
MCP Server

Can provision its own MCP server with an AI tool connected



UI Dashboard with Headlamp





Demo Time

1. Kubescape CLI: scan a cluster and apply remediation
2. Headlamp UI: Kubescape plugin dashboard

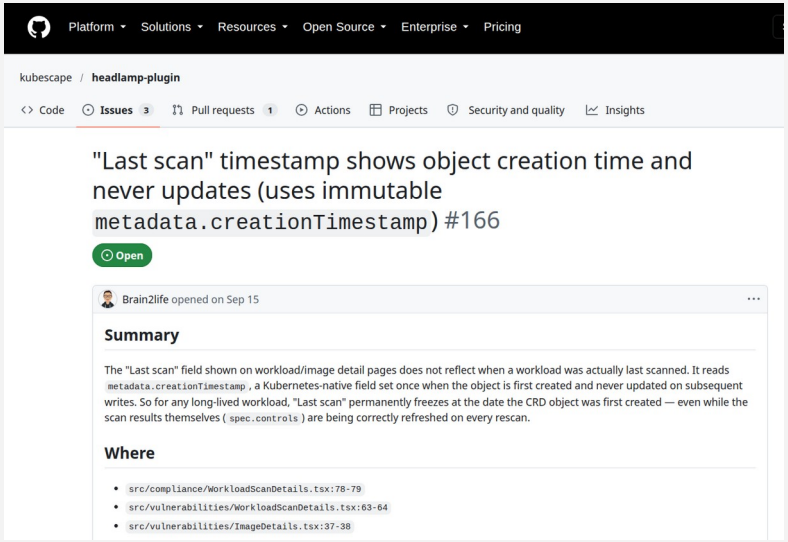


Demo



"Last Scan" Time Never Updates

- "Last scan" stayed on the same date, so we thought scanning was broken
- It was not: `resourceVersion` went from 3 to 167+, results kept refreshing
- The plugin shows `metadata.creationTimestamp`, which is set once and never changes
- Reported as headlamp-plugin issue #166; fixes are in progress
- Lesson: check the raw objects with kubectl before blaming the scanner



Headlamp Data Is Not Updated Properly

- The Headlamp plugin reads scan-result CRDs, and they did not refresh reliably
- Workaround: a daily CronJob deletes the compliance CRDs, then the scheduler's full scan repopulates them
- Run it a few minutes before kubescape-scheduler (its schedule is hashed per cluster)
- Result: fresh once a day, not real-time

```
# Helm values
complianceCrdReset:
  enabled: true
  # a few minutes BEFORE
  # kubescape-scheduler
  schedule: "53 2 * * *"

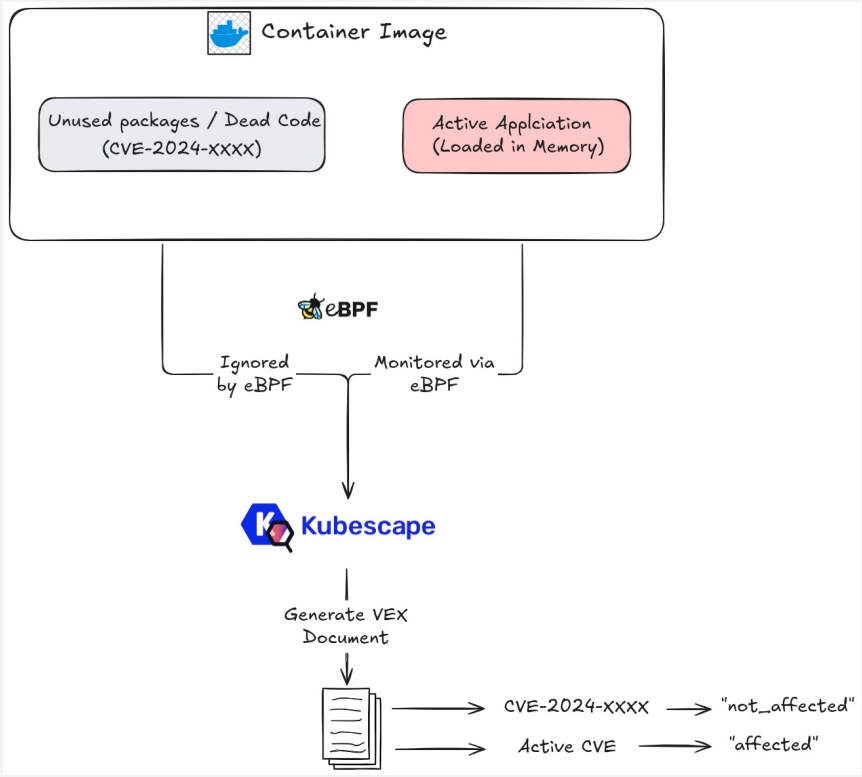
# check the scheduler time:
kubectl get cronjob \
  kubescape-scheduler \
  -n kubescape \
  -o jsonpath='{.spec.schedule}'
```



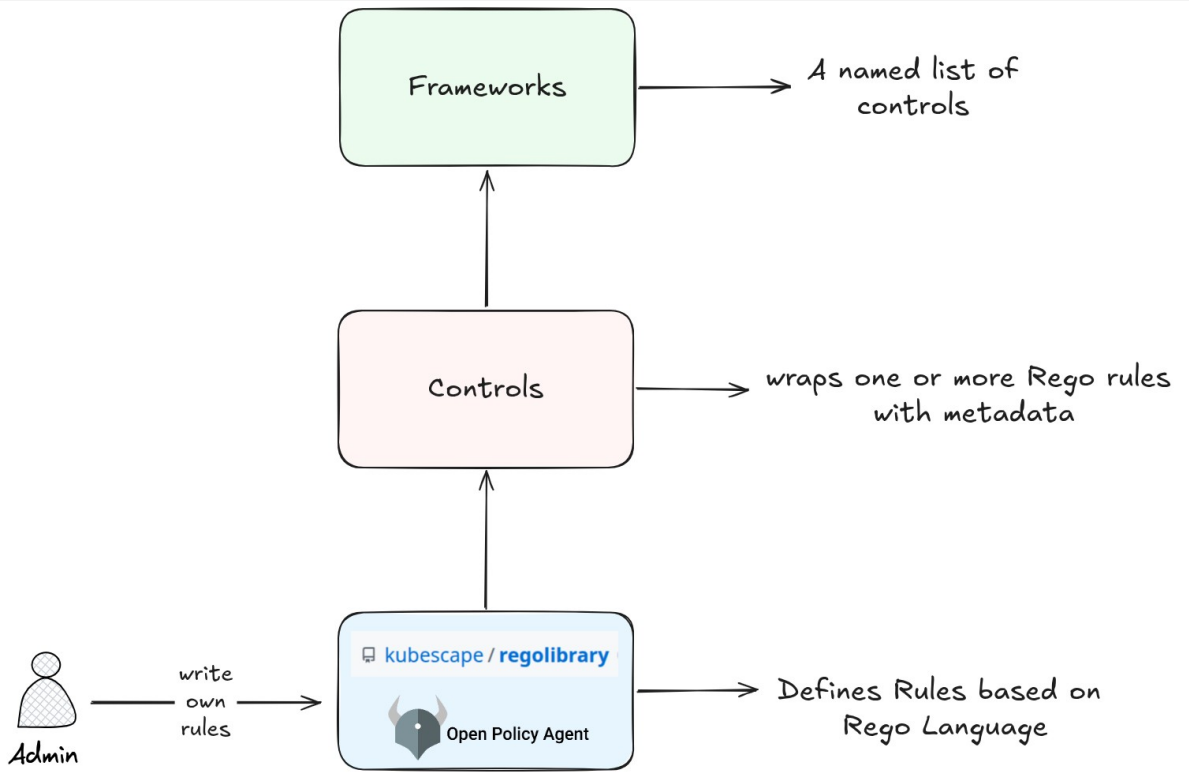
VEX Reports

Generates VEX documents for security teams

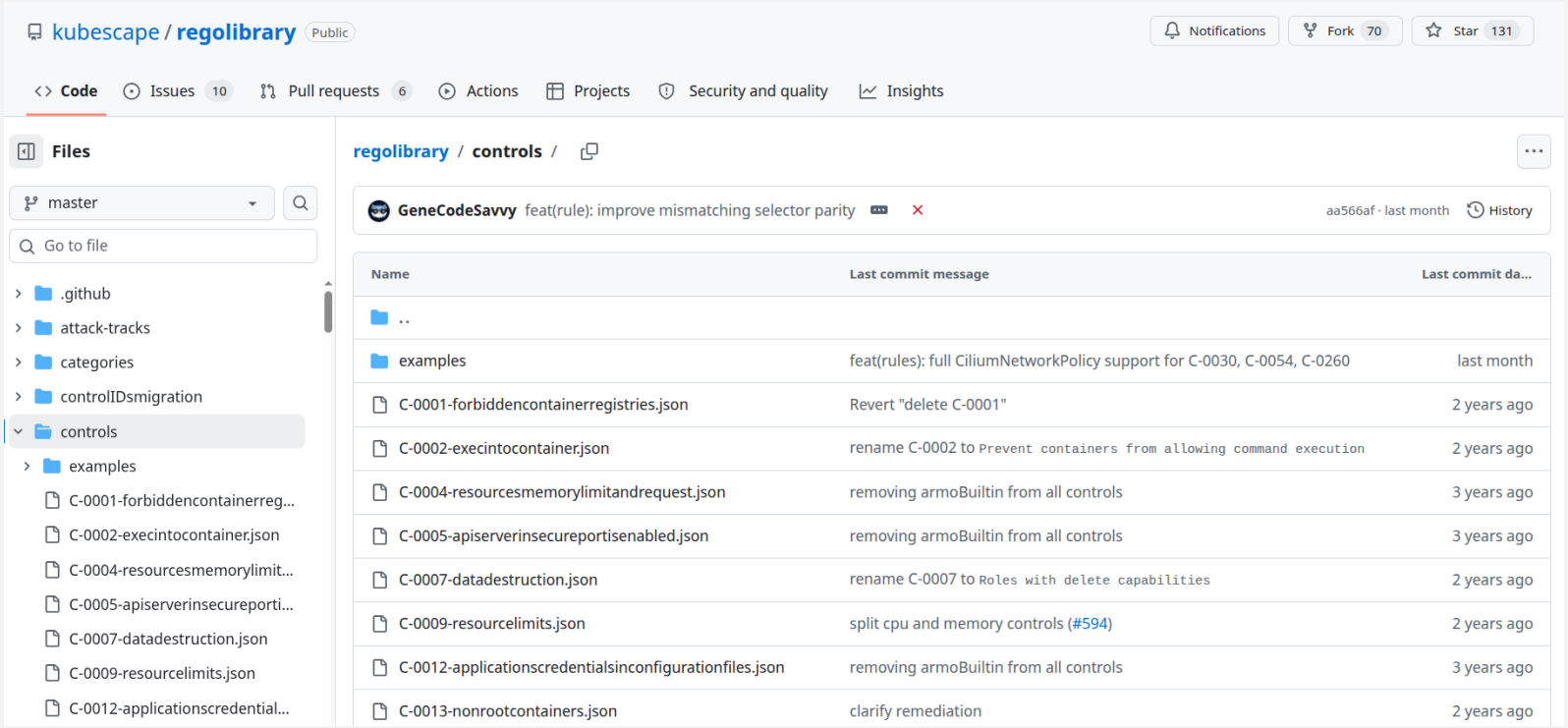
```
    ],
    "status": "not_affected",
    "vulnerability": {
      "@id": "https://nvd.nist.gov/vuln/detail/CVE-2025-46394",
      "description": "In tar in BusyBox through 1.37.0, a TAR archive can have
      "name": "CVE-2025-46394"
    }
  },
    ],
    "status": "affected",
    "vulnerability": {
      "@id": "https://nvd.nist.gov/vuln/detail/CVE-2025-4674",
      "description": "The go command may execute unexpected commands whe
      "name": "CVE-2025-4674"
    }
  }
],
```



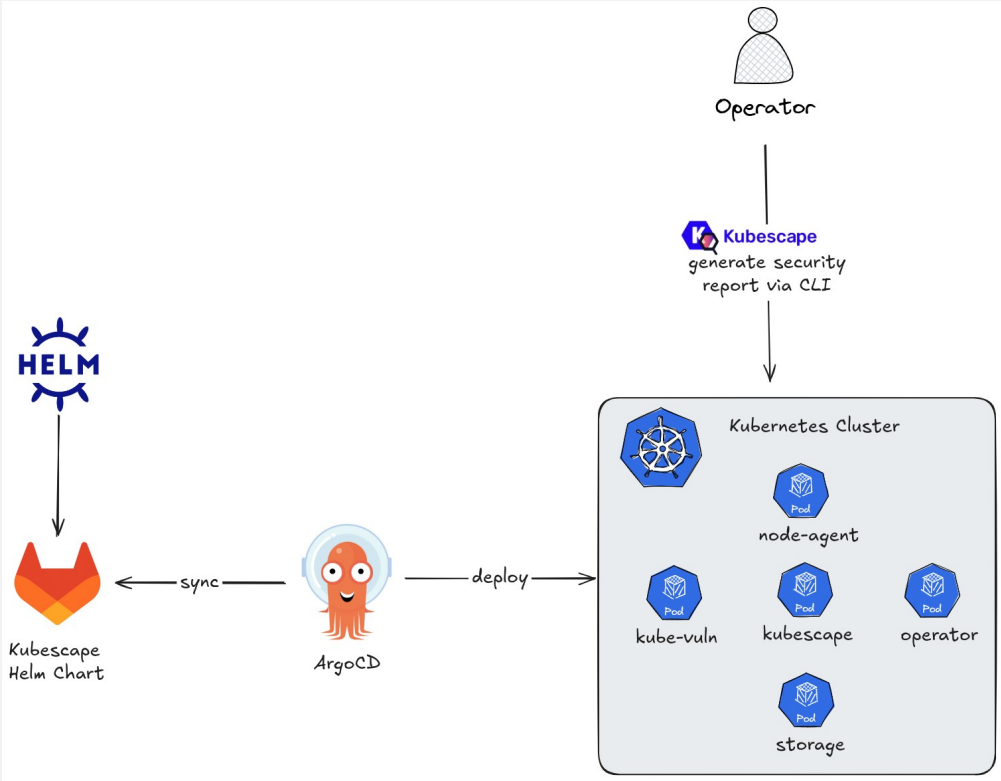
Create Your Own Baseline Framework



Create Your Own Baseline Framework



Dynamic Kubescape



Kubescape Helm Values

```yaml
kubescape-operator:
  clusterName: test-cluster

  excludeNamespaces: "kubescape,kube-system,kube-public,kube-node-lease,kubeconfig,gmp-system,gmp-public,cattle-system"

  capabilities:
    configurationScan: disable
    continuousScan: disable
    nodeScan: disable
    vulnerabilityScan: disable

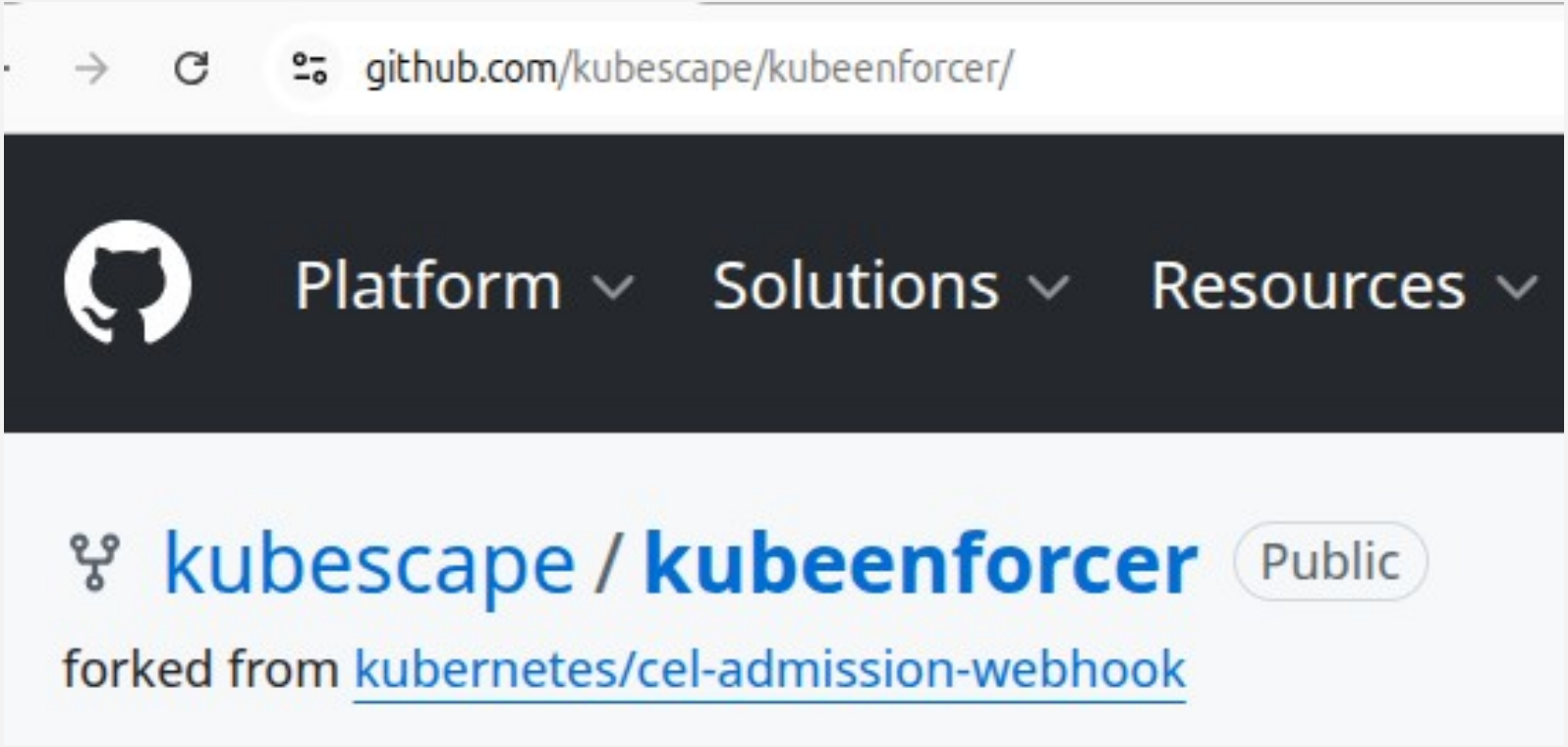
  grypeOfflineDB:
    enabled: true

  persistence:
    storageClass: longhorn

  kubevuln:
    tmpDirPersistence:
      enabled: true
      storageClassName: longhorn
      size: 3Gi
    config:
      grypeDbPersistence: true
```



Kubeenforcer for Alertmanager



Kubeenforcer Configs

```yaml
kind: ConfigMap
apiVersion: v1
metadata:
  name: alertmanager-config
  namespace: kubescape
data:
  alertmanager.yml: |-
    global:
      smtp_smarthost: smtp-server:port   # SMTP server and port
      smtp_from: sender@email.com    # Sender email address
      smtp_auth_username: ""     # SMTP username
      smtp_auth_password: ""     # SMTP password
      smtp_require_tls: true               # Require TLS encryption

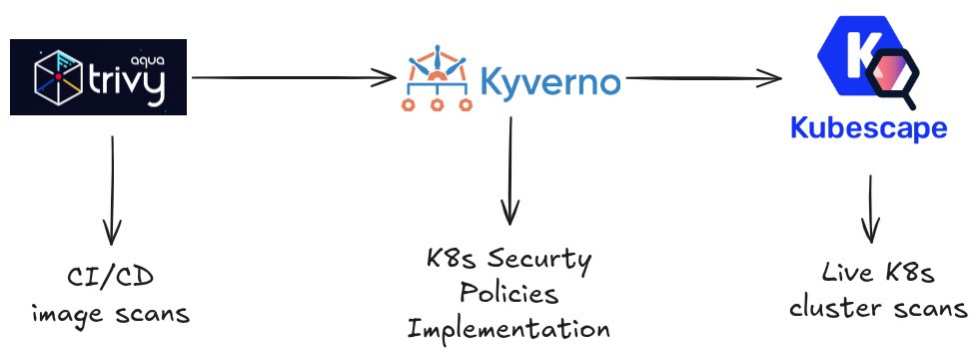
    route:
      group_by: ['alertname']
      receiver: email-notifier

    receivers:
    - name: email-notifier
      email_configs:
      - to: your@email.com
```



What Value Does Kubescape Provide?

- Covers static and dynamic analysis of your Kubernetes environment and its configuration
- Lets you build a custom security framework aligned with your organization's security policies
- Reduces security noise and prioritizes "real" risks with VEX reports



The main idea

Kubescape gives you one open-source tool to see your Kubernetes risk at every stage: manifests, images and the live cluster.

It’s not a silver bullet, but it shines in combination with other tools like Trivy and Kyverno.



Your feedback matters: scan the QR code to share your thoughts



ANDERSEN

THANK YOU